

Marco integrativo GQM + PRAGMATIC para indicadores GRC nacionales de ciberseguridad (España)

Versión 1.0 – 2026

1. Propósito del marco

Este marco integra la metodología GQM (Goal–Question–Metric) con la evaluación PRAGMATIC para diseñar y evaluar indicadores nacionales de Gobernanza, Riesgo y Cumplimiento (GRC) en ciberseguridad, con énfasis en España y alineamiento con NIS2/NIS360, NIST CSF/RMF y las estrategias digitales nacionales y europeas.[web:9][web:12][web:13][web:5][web:3]

El objetivo es garantizar que cada dato técnico recogido (métrica) pueda rastrearse hasta objetivos estratégicos nacionales y, al mismo tiempo, que cada métrica sea evaluada según los nueve criterios PRAGMATIC: Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente y Rentable.

2. Resumen de la metodología GQM

La metodología GQM se articula en tres niveles:

1. Goal (Objetivo): definir, en lenguaje de negocio y política pública, qué se pretende lograr o conocer.
2. Question (Pregunta): derivar cuestiones que, al responderse, permitan evaluar el grado de cumplimiento del objetivo.
3. Metric (Métrica): definir medidas concretas (cuantitativas o cualitativas) que respondan a las preguntas.

En este marco, los **objetivos** se formulan a nivel nacional (por ejemplo, “reforzar la resiliencia de servicios esenciales conforme a NIS2”), las **preguntas** se aplican a organizaciones individuales y las **métricas** son datos que pueden agregarse y analizarse a nivel sectorial y país.[web:9][web:12]

3. Criterios PRAGMATIC

Cada métrica definida se evalúa con los nueve criterios PRAGMATIC:

- P – Predictivo: ¿La métrica anticipa el futuro comportamiento del riesgo o la madurez?
- R – Relevante: ¿Está claramente vinculada a objetivos estratégicos y normativos?
- A – Accionable: ¿Sugiere acciones concretas o decisiones?
- G – Genuino: ¿Mide lo que dice medir, sin efectos cosméticos?
- M – Significativo (Meaningful): ¿Es comprensible y significativa para las partes interesadas?
- P – Preciso (Precise): ¿Es suficientemente exacta y consistente?
- T – Oportuno (Timely): ¿Está disponible con la frecuencia necesaria?
- I – Independiente: ¿No es fácilmente manipulable ni dependiente de una única fuente sesgada?
- C – Rentable (Cost-effective): ¿Su obtención compensa el coste de medirla?

Cada métrica se califica típicamente en una escala 0–3 para cada criterio (0 = no cumple, 1 = pobre, 2 = razonable, 3 = alto nivel), permitiendo una valoración global de su utilidad.

4. Dominios GRC nacionales y macro-objetivos

A partir del informe GRC previo, se consideran cuatro grandes dominios de indicadores nacionales:

4. Gobernanza (GOB): marco institucional, estrategia, roles, métricas de alto nivel.[web:8][web:12]
5. Riesgo (RIESGO): incidentes, madurez vs. criticidad, gestión de riesgos.[web:9][web:3]
6. Cumplimiento (CUMP): alineamiento con NIS2, ENS, DORA, ISO 27001, etc.[web:9][web:5]
7. Capacidades y resiliencia (CAP+RES): Zero Trust, detección y respuesta, continuidad, inversión.
[web:1][web:3]

Cada dominio se articula en objetivos QGM. A efectos prácticos, este marco se centra en un conjunto de **indicadores tipo** representativos, que luego pueden extenderse.

5. Ejemplos de QGM por dominio

5.1. Gobernanza (GOB)

Objetivo GOB-1: Asegurar que las organizaciones críticas en España disponen de una gobernanza de ciberseguridad alineada con NIS2 y la Estrategia Nacional de Ciberseguridad.[web:9][web:3]

- Pregunta GOB-1.1: ¿Las organizaciones cuentan con una estrategia formal de ciberseguridad aprobada por el máximo órgano de gobierno?
- Métrica GOB-1.1.a: Porcentaje de organizaciones críticas con estrategia de ciberseguridad formalmente aprobada en los últimos 3 años.
- Pregunta GOB-1.2: ¿Existe un responsable ejecutivo claro (CISO u equivalente) con acceso regular a la alta dirección?
- Métrica GOB-1.2.a: Porcentaje de organizaciones con CISO designado y acceso al consejo/comités al menos trimestralmente.
- Pregunta GOB-1.3: ¿Se dispone de cuadros de mando de ciberseguridad integrados en el reporting corporativo?
- Métrica GOB-1.3.a: Porcentaje de organizaciones que reportan métricas de ciberseguridad al máximo órgano de gobierno al menos semestralmente.

5.2. Riesgo (RIESGO)

Objetivo RIESGO-1: Conocer y reducir la brecha entre criticidad de servicios y madurez de ciberseguridad, siguiendo el enfoque NIS360.[web:9][web:12]

- Pregunta RIESGO-1.1: ¿Se han identificado y categorizado los servicios críticos según NIS2/estrategia nacional?
- Métrica RIESGO-1.1.a: Porcentaje de organizaciones que han mapeado servicios críticos a activos tecnológicos.
- Pregunta RIESGO-1.2: ¿En qué medida la madurez de ciberseguridad está alineada con la criticidad?
- Métrica RIESGO-1.2.a: Número de sectores en “zona de riesgo” (criticidad alta, madurez baja) según evaluación agregada.
- Pregunta RIESGO-1.3: ¿Con qué frecuencia se realizan análisis de riesgos formales?
- Métrica RIESGO-1.3.a: Porcentaje de organizaciones que realizan análisis de riesgos al menos anualmente.

5.3. Cumplimiento (CUMP)

Objetivo CUMP-1: Asegurar que las organizaciones alcanzan y mantienen un nivel de cumplimiento adecuado con NIS2, ENS y marcos conexos.[web:9][web:5][web:12]

- Pregunta CUMP-1.1: ¿Hasta qué punto las organizaciones cumplen los requisitos de gestión de riesgos de NIS2/ENS?
- Métrica CUMP-1.1.a: Porcentaje de organizaciones que declaran nivel de cumplimiento “alto” o “sistemático” con los marcos aplicables.
- Pregunta CUMP-1.2: ¿Se verifica el cumplimiento mediante auditorías internas/externas periódicas?
- Métrica CUMP-1.2.a: Porcentaje de organizaciones con auditorías de ciberseguridad realizadas en los últimos 24 meses.
- Pregunta CUMP-1.3: ¿Se dispone de inventarios de controles mapeados a requisitos normativos?
- Métrica CUMP-1.3.a: Porcentaje de organizaciones con inventario de controles mapeado a NIS2/ENS/ISO 27001.

5.4. Capacidades y resiliencia (CAP+RES)

Objetivo CAP-1: Evaluar y mejorar la adopción de principios de Zero Trust, detección, respuesta y continuidad en las organizaciones clave.[web:1][web:9]

- Pregunta CAP-1.1: ¿Cuál es el nivel de madurez en gestión de identidades y accesos (IAM/PAM, MFA)?
- Métrica CAP-1.1.a: Porcentaje de organizaciones con MFA extendido a todos los usuarios internos.
- Pregunta CAP-1.2: ¿Qué grado de adopción existe de arquitecturas Zero Trust / ZTNA/SASE?
- Métrica CAP-1.2.a: Porcentaje de organizaciones que utilizan ZTNA/SASE como modelo predominante de acceso remoto.
- Pregunta CAP-1.3: ¿Qué capacidades de detección y respuesta están desplegadas?
- Métrica CAP-1.3.a: Porcentaje de organizaciones con SOC (interno o gestionado) 24×7 con EDR/XDR.
- Pregunta RES-1.1: ¿La planificación de continuidad incluye escenarios de ciberincidentes?
- Métrica RES-1.1.a: Porcentaje de organizaciones con BCP/DRP que contempla ciberataques y se prueba periódicamente.

6. Integración con la encuesta organizacional

Las métricas anteriores se alimentan directamente de las respuestas de la encuesta GRC: cada pregunta de la encuesta se asocia a uno o más elementos GQM y a uno o más marcos normativos. El resultado es una cadena clara:

Estrategia nacional → Objetivo GQM → Preguntas a organizaciones → Métricas agregadas → Decisiones de política pública.

Esta trazabilidad permite evaluar no solo la madurez de las organizaciones, sino también la efectividad de la política nacional de ciberseguridad.

7. Aplicación del filtro PRAGMATIC

Para cada métrica definida se elabora una mini-ficha que incluye:

- Definición precisa de la métrica.
- Fuente de datos (encuesta, registros nacionales, etc.).
- Frecuencia de recogida.
- Unidad de medida y rango esperado.
- Evaluación PRAGMATIC (0–3 en cada criterio).

Las métricas con baja puntuación global PRAGMATIC se revisan, redefinen o eliminan. No todo lo que es medible merece ser medido.

8. Uso del marco

Este marco GQM + PRAGMATIC se utiliza como:

- Guía para diseñar y revisar indicadores nacionales.
- Referencia para evaluar si nuevas métricas propuestas tienen sentido estratégico.
- Mecanismo de comunicación entre técnicos, gestores y responsables políticos.

Si todo sale razonablemente bien, el resultado será un ecosistema de indicadores menos decorativo y más útil para decidir dónde invertir, qué regular y qué aceptar con un cierto estoicismo digital.